

AUDIT QUALITÉ & SÉCURITÉ DE LA STACK OPEN SOURCE

Nextcloud – Suricata – Keycloak

Date : 1er juin 2026

1. Tableau d'audit

Projet	Scorecard	Vulnérabilités Grype	Gouvernance	Risque
Nextcloud	6.6 / 10	6 vulnérabilités (0 critiques)	Communauté active	Modéré
Suricata	8.6 / 10	0 vulnérabilité	Très forte gouvernance	Faible
Keycloak	9.3 / 10	15 vulnérabilités (1 critique)	Gouvernance Red Hat	Élevé

2. Rapport de synthèse

Cet audit vise à évaluer la qualité, la sécurité et la gouvernance des projets Nextcloud, Suricata et Keycloak avant leur déploiement. Les outils utilisés sont OpenSSF Scorecard, Dependency-Check, CycloneDX SBOM, Grype et l'analyse des CVE.

Analyse Scorecard

Nextcloud obtient 6,6/10 grâce à une communauté active et des pratiques de développement correctes, mais souffre d'un grand nombre de dépendances. Suricata obtient 8,6/10 avec une gouvernance mature et peu de faiblesses identifiées. Keycloak atteint 9,3/10 grâce au support de Red Hat, à une politique de sécurité robuste et à une intégration continue complète.

Analyse des dépendances

L'analyse Dependency-Check n'a révélé aucune dépendance vulnérable dans les dépôts analysés. Les rapports sont vides car les dépendances compilées n'étaient pas présentes localement.

Analyse SBOM CycloneDX

Un SBOM CycloneDX 1.7 a été généré pour Suricata. Le fichier contient les métadonnées nécessaires à la traçabilité des composants logiciels.

Analyse Gype

Projet	Vulnérabilités	Critiques	Risque
Nextcloud	6	0	Modéré
Suricata	0	0	Faible
Keycloak	15	1	Élevé

3. Liste des CVE critiques

Référence	CVSS	Description	Statut
GHSA-5xrq-8626-4rwp	9.8	Exécution de code à distance via Vitest	Patch disponible
GHSA-c2c7-rcm5-vvqj	8.2	Vulnérabilité dans picomatch	Patch disponible
GHSA-rqfh-9r24-8c9r	7.5	Contournement de validation AssertJ	Patch disponible

4. Synthèse des risques

Nextcloud présente un risque modéré lié à ses dépendances. Suricata présente un risque faible grâce à l'absence de vulnérabilités détectées. Keycloak présente le risque le plus élevé en raison d'un nombre important de vulnérabilités dans ses dépendances malgré son excellent score de gouvernance.

5. Recommandations

Nextcloud : mettre à jour les dépendances NPM, activer CSP et vérifier les plugins tiers.

Suricata : maintenir les signatures IDS à jour et surveiller les performances en production.

Keycloak : mettre à jour vers une version LTS, supprimer les dépendances de test inutiles et renforcer les en-têtes de sécurité.

6. Extrait SBOM CycloneDX

Commande utilisée : `trivy fs --format cyclonedx --output sbom.json` .

bomFormat: CycloneDX | specVersion: 1.7 | timestamp: 2026-06-10T19:29:43+00:00

```
{
  "$schema": "http://cyclonedx.org/schema/bom-1.7.schema.json",
  "bomFormat": "CycloneDX",
  "specVersion": "1.7",
  "serialNumber": "urn:uuid:9f58cb29-2f51-4b92-9771-5df44214e728",
```

```
"version": 1,  
"metadata": {  
  "timestamp": "2026-06-10T19:29:43+00:00"  
}  
}
```

Conclusion générale

Suricata est le composant le plus sûr et le mieux gouverné. Nextcloud présente un risque modéré tandis que Keycloak nécessite des actions correctives prioritaires avant déploiement. Les recommandations proposées permettront de réduire significativement la surface d'attaque de la plateforme.